

Cybersecurity Risk Assessment Framework **for Small and Medium Enterprises (SMEs)**

A Practical Model for Identifying, Scoring and Mitigating Cyber Risk in Resource-Constrained Organisations

Prepared by: Lokesh
Minor Project - 1 | Internship Submission

1. Executive Summary

Small and medium enterprises are increasingly the preferred target for attackers, not because the payoff is larger, but because the defences are thinner. Most SMEs run lean IT teams, rely on a handful of shared logins, and treat security as something to revisit only after an incident. This report builds a lightweight, repeatable risk assessment framework that an SME with limited budget and staff can actually use, rather than a compliance document that gets filed away and forgotten.

The framework is built around the five functions of the NIST Cybersecurity Framework (Identify, Protect, Detect, Respond, Recover), paired with a simple Likelihood x Impact scoring matrix so that risks can be ranked and prioritised instead of tackled in random order. Two case studies are used to validate the model against realistic SME environments, and the report closes with a set of best-practice recommendations that can be implemented in phases as budget allows.

2. Introduction

Cybersecurity is often discussed at the enterprise level, where dedicated security operations teams and six-figure tooling budgets are the norm. SMEs operate under very different constraints - a single IT administrator (or an outsourced MSP) is frequently responsible for everything from helpdesk tickets to firewall rules. This gap between what large enterprises can afford and what a 15-50 person company can realistically maintain is exactly where most breaches occur.

This project sets out to answer a practical question: what is the minimum set of steps an SME can follow to know where it stands security-wise, and to decide what to fix first? The answer proposed here is a four-part framework: identify the risks relevant to an SME's environment, score them consistently, apply proportionate mitigations, and revisit the assessment periodically rather than treating it as a one-time exercise.

3. Common Cybersecurity Risks in SMEs

Research into SME breach reports (Verizon DBIR, IBM Cost of a Data Breach, and industry advisories from CERT-In) consistently points to a small set of recurring risk categories. These were used as the basis for this assessment rather than a generic textbook list, since the goal is relevance to real SME environments.

3.1 Phishing and Business Email Compromise

Still the single most common entry point. SMEs rarely run phishing simulations or advanced email filtering, and a single compromised inbox is often enough to redirect an invoice payment or pivot into the internal network.

3.2 Ransomware

SMEs are attractive ransomware targets precisely because they are more likely to pay quickly - downtime is existential when there is no dedicated incident response capability. Weak backup hygiene compounds this risk significantly.

3.3 Insider Threats

Not always malicious - most insider incidents in SMEs stem from over-provisioned access, employees using personal devices for work, or simple mistakes (sending a file to the wrong recipient, misconfiguring a shared folder).

3.4 Weak Identity and Access Practices

Shared admin logins, no MFA, and passwords that never expire are still common in SME environments, largely because enabling stronger controls is seen as an inconvenience rather than a necessity.

3.5 Unpatched Systems and Legacy Software

Budget constraints often mean SMEs keep running older, unsupported software because replacing it is expensive. This leaves known, publicly documented vulnerabilities open for extended periods.

3.6 Third-Party and Cloud Misconfigurations

As SMEs move workloads to platforms like AWS, Azure, or Google Workspace, misconfigured storage buckets and overly permissive sharing settings have become a growing source of accidental data exposure.

4. Risk Assessment Model

The assessment model adopted here is based on the NIST Cybersecurity Framework (CSF), chosen because it is vendor-neutral, widely recognised, and scalable down to organisations with minimal security staff. Rather than implementing the full NIST CSF (which is written for larger organisations), this project adapts its five core functions into an SME-appropriate checklist.

4.1 Identify

Build a lightweight asset inventory - devices, cloud accounts, critical data, and who has access to what. Most SMEs skip this step entirely, which makes every later step guesswork.

4.2 Protect

Apply baseline safeguards: MFA on all business accounts, endpoint protection, a documented password policy, and role-based access control so employees only have the access their job actually requires.

4.3 Detect

Even without a full SOC, low-cost detection is achievable - centralised logging (e.g. via a free-tier SIEM or built-in cloud audit logs), alerting on failed logins, and basic anomaly monitoring on critical accounts.

4.4 Respond

A short, one-page incident response plan naming who does what during a breach (who isolates the affected system, who notifies stakeholders, who contacts law enforcement/CERT-In if required) removes the panic factor when an incident actually happens.

4.5 Recover

Tested backups (not just scheduled ones - actually test-restored periodically) and a documented recovery time objective for critical systems, so the business knows realistically how long an outage will last.

5. Risk Evaluation Matrix

To move from a list of risks to a prioritised action plan, each risk identified in Section 3 is scored on two dimensions, each rated 1 (lowest) to 5 (highest):

- Likelihood - how probable is this risk given the SME's current environment and industry
- Impact - how severe would the consequence be (financial, operational, reputational) if it occurred

Risk Score = Likelihood x Impact (max 25). Scores are then bucketed as Critical (16-25), High (10-15), Medium (5-9), and Low (1-4), which maps directly to a remediation timeline.

Risk	Likelihood (1-5)	Impact (1-5)	Score	Priority
Phishing / Business Email Compromise	5	4	20 - Critical	Immediate
Ransomware	3	5	15 - High	Immediate
Insider Threats (accidental or malicious)	3	4	12 - High	Short-term
Weak / Reused Passwords	4	3	12 - High	Short-term
Unpatched Software & OS	4	3	12 - High	Short-term
Unsecured Remote Access (RDP/VPN)	3	4	12 - High	Short-term
Third-Party / Vendor Risk	2	4	8 - Medium	Medium-term
Lost or Stolen Devices	2	3	6 - Medium	Medium-term
Misconfigured Cloud Storage	2	3	6 - Medium	Medium-term
Outdated Backup Practices	2	3	6 - Medium	Medium-term

Note: scores above reflect a typical 20-50 employee SME with moderate cloud adoption and no dedicated security staff; likelihood/impact values should be re-scored for the specific business being assessed - this is precisely what the two case studies in Section 7 demonstrate.

6. Risk Mitigation Strategies

Mitigations are mapped directly against the risks scored above, and are deliberately chosen to be achievable without enterprise-grade budgets. Implementation cost is flagged as Low, Medium, or High to help an SME sequence its rollout.

Risk	Recommended Mitigation	Relative Cost
Phishing / BEC	Email filtering (SPF/DKIM/DMARC), simulated phishing drills, MFA on email accounts	Low
Ransomware	Endpoint detection & response (EDR), offline/immutable backups, application whitelisting	Medium
Insider Threats	Role-based access control, least-privilege policy, activity logging & review	Low
Weak Passwords	Password manager rollout, minimum complexity policy, MFA everywhere	Low

Risk	Recommended Mitigation	Relative Cost
Unpatched Software	Automated patch management, scheduled maintenance windows	Low
Unsecured Remote Access	VPN with MFA, disabling direct RDP exposure, IP allow-listing	Low
Vendor Risk	Vendor security questionnaires, contractual SLAs, periodic audits	Medium
Cloud Misconfiguration	Cloud Security Posture checks, encryption at rest, access reviews	Medium

Three controls appear repeatedly across almost every risk category above, and are therefore treated as the non-negotiable baseline for any SME: multi-factor authentication on every account that supports it, a properly configured firewall (host and network level), and recurring, non-technical employee security awareness training. These three alone address a disproportionate share of the SME breach surface at comparatively low cost.

7. Case Studies

The framework above was applied to two fictional but realistic SME profiles to validate that the scoring model produces sensible, differentiated results rather than a one-size-fits-all output.

7.1 Case Study A - Retail Business (32 employees, on-prem POS + cloud accounting)

A single-location retail business running a point-of-sale system on a local server, with accounting handled through a cloud SaaS product. IT is outsourced part-time to a local vendor. Applying the model: Ransomware scored Critical (5x5=25) here specifically because backups were found to be manual and infrequent, and the POS system was running an unsupported OS version. Phishing scored High (4x4=16), since the office manager handles vendor payments directly over email with no verification step. Recommended first actions: migrate to automated, tested backups; enable MFA on the accounting SaaS account; and introduce a simple call-back verification step before any payment change is processed.

7.2 Case Study B - Software Consultancy (45 employees, fully cloud-based, remote-first)

A remote-first consultancy using AWS for client workloads and Google Workspace for internal collaboration. No physical office server to secure, but a much larger attack surface through personal devices and cloud IAM. Here, Insider Threats and Cloud Misconfiguration scored higher relative to the retail case (12 and 9 respectively) due to broad IAM permissions granted to consultants for convenience, and the use of personal laptops without endpoint management. Ransomware scored comparatively lower (3x3=9) given strong, versioned cloud backups already in place. Recommended first actions: enforce least-privilege IAM roles per project, mandate MDM enrolment for any device accessing client data, and enable audit logging on all cloud accounts.

The differentiated scores between the two cases confirm the model is not just producing the same output regardless of input - environment-specific factors materially change both the ranking and the recommended remediation order, which is the intended behaviour of the framework.

8. Best Practices and Recommendations

- Treat this as a living assessment - re-score risks at least every two quarters, or after any major infrastructure change.
- Start with the three non-negotiables (MFA, firewalls, employee training) before investing in more advanced tooling.
- Keep the asset inventory (Identify function) up to date - an assessment is only as good as the visibility behind it.
- Test backups by actually restoring them, not just confirming the backup job completed successfully.
- Document a one-page incident response plan - clarity during an actual incident is more valuable than a lengthy policy nobody reads.
- Where budget allows, prioritise Detect capability next - most SMEs have Protect controls but very limited visibility into what is actually happening on their network.

9. Conclusion

The exercise reinforces a point that is easy to state but hard to act on: SME cybersecurity does not fail because good frameworks don't exist, it fails because existing frameworks are written for organisations with far more resources than a typical SME has. By adapting NIST CSF into a lightweight, scored, and repeatable process, this framework gives an SME owner or IT administrator a concrete answer to the question 'what should I fix first', which is ultimately more useful than a comprehensive but unprioritised list of everything that could go wrong.

References

- NIST Cybersecurity Framework (CSF) 2.0 - National Institute of Standards and Technology
- Verizon Data Breach Investigations Report (DBIR), latest edition
- IBM Cost of a Data Breach Report
- CERT-In Advisories, Indian Computer Emergency Response Team
- CIS Critical Security Controls, Center for Internet Security